



ALMA MATER STUDIORUM  
UNIVERSITÀ DI BOLOGNA

# Laboratorio di Sicurezza Informatica

**Marco Prandini**

Dipartimento di Informatica – Scienza e Ingegneria

# La sicurezza informatica ci riguarda?

- Sì, ben prima che come professionisti. Nelle nostre vite

- Infrastrutture critiche per la “civiltà”
- Sistemi di comunicazione ed elaborazione delle informazioni
- Archivi di informazioni personali

sono tutti elementi *informatizzati* ormai irrinunciabili e in molti casi, se **danneggiati**, insostituibili (in assoluto o in tempo utile per evitare conseguenze gravi)

- *Sicurezza informatica* è tutto ciò che ha a che fare col contrasto di **azioni deliberate** che provochino danni

- Termini diversi hanno sfumature specifiche, ma spesso sono usati “popolarmente” in modo intercambiabile: sicurezza dell’informazione, IT security, cybersecurity, ...
- Useremo sicurezza nel senso del termine inglese *security* ricordando che in italiano significa anche contrasto di eventi accidentali che provochino danni (in inglese tradotto *safety*)

# Impatto sociale della cyber(in)security

Woman dies during a ransomware attack on a German hospital

The Verge, Sep 17, 2020



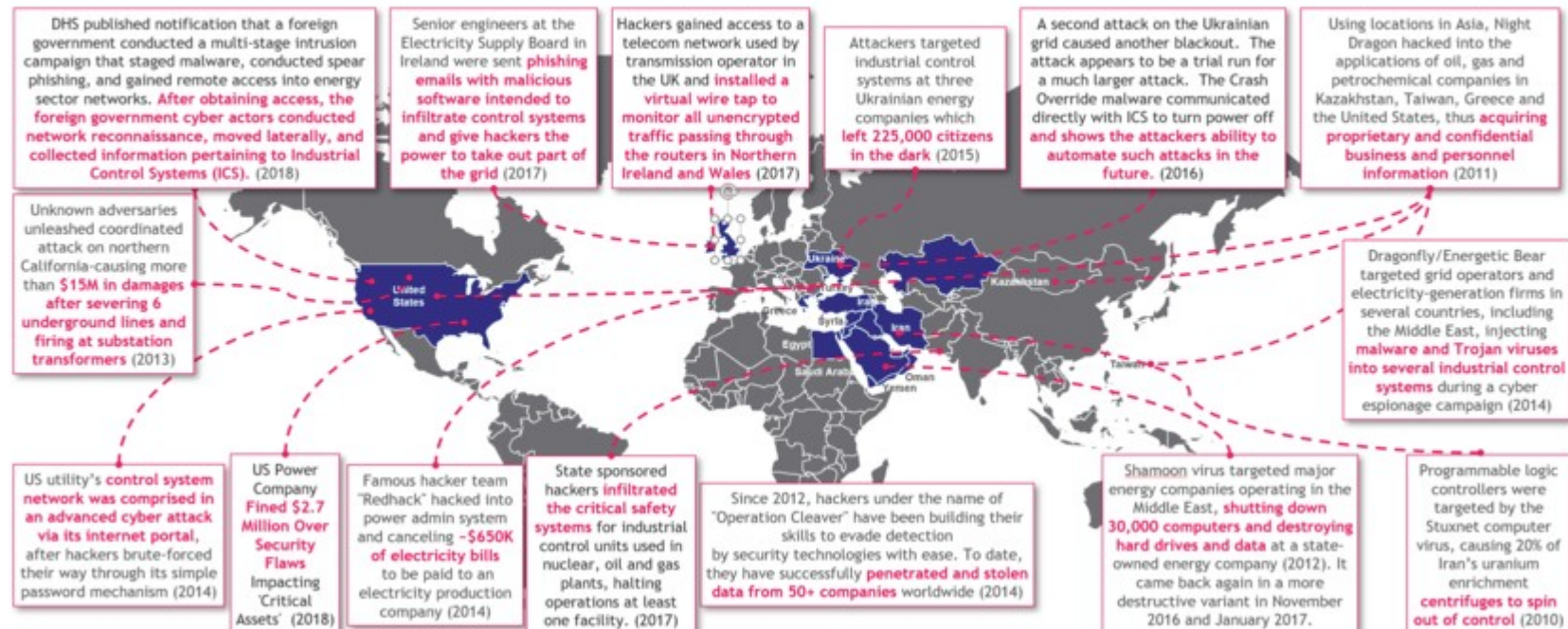
2000: Maroochy waste management

2008: Refahiye pipeline

2018: Saudi Chemical Company

2020: Natanz “stuxnet 2”

Hackers are causing blackouts. It's time to boost our cyber resilience. World Economic Forum, Mar 27, 2019



# Impatto economico della cyber(in)security

- “Se il cybercrime fosse una nazione, sarebbe nel G3, con un GDP > 10T\$ previsto per il 2025”



*titolo un po' sensazionalistico, è la stima peggiore dei danni causati, non dei guadagni, e circolano anche cifre minori*

*comunque, con una crescita prevista annua del 10-15%, ci arriverà...*

- Un business criminale in crescita
  - Più lucrativo del mercato mondiale della droga
  - Più dannoso di tutti i disastri naturali cumulati (per ora...)
- Un modello criminale attrattivo
  - Utilizzabile in innumerevoli settori
  - A basso rischio (0,05%) di individuazione e prosecuzione legale
- ◆ Ma anche un mercato del lavoro lecito alimentato da investimenti ingenti per la difesa
  - Cresciuto del 12-15% all'anno negli ultimi anni
  - 2018-2021 totalizzati 1000 miliardi \$
  - Solo nel 2025: spesi 300 miliardi di US\$

# Proprietà di sicurezza

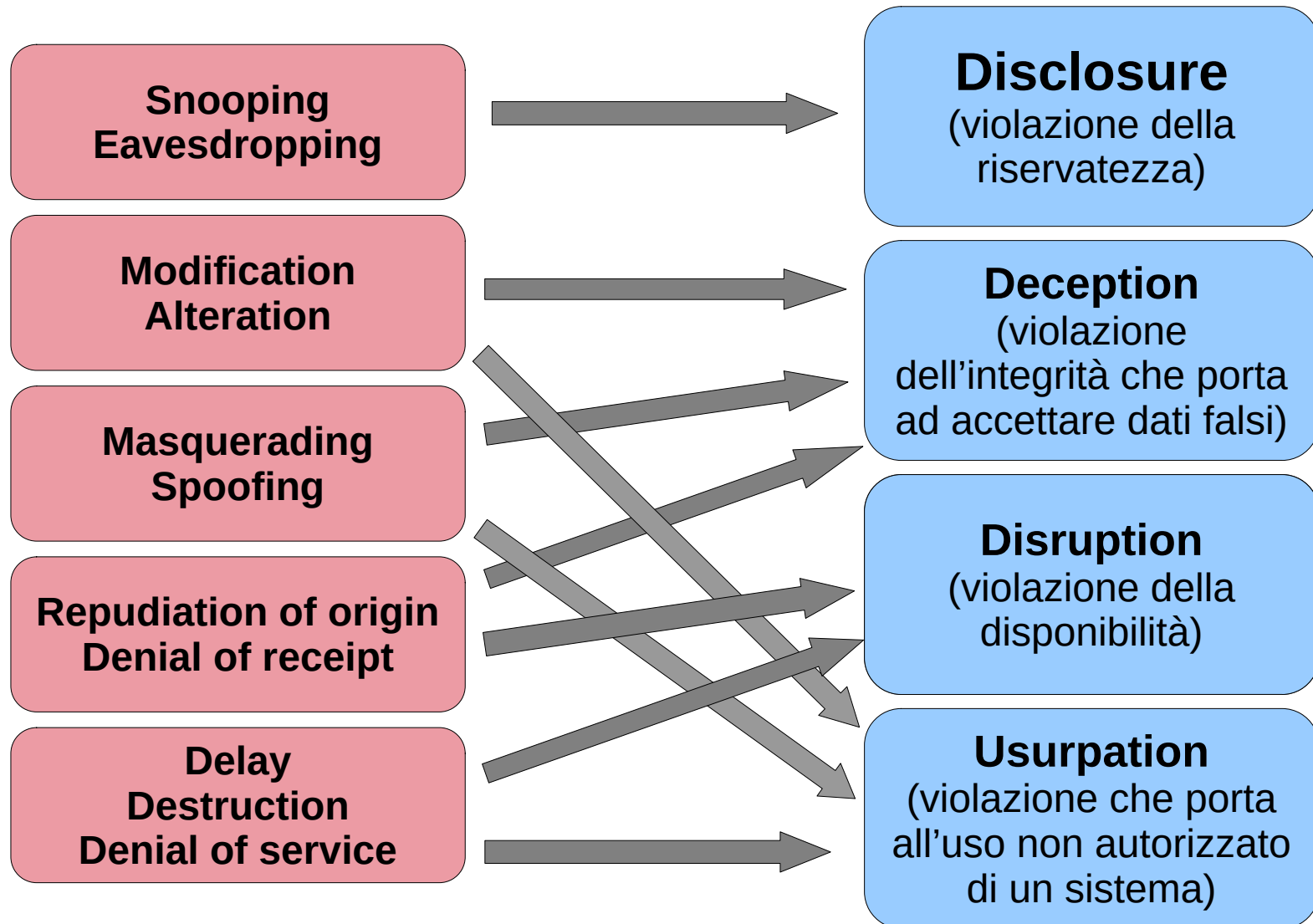
- La sicurezza di un sistema può essere scomposta in tre proprietà chiave, riassunte dalla sigla **CIA**
- Confidentiality (riservatezza)
  - Mantenere inaccessibili dati, o proprietà di un sistema, a chi non sia autorizzato a conoscerli
- Integrity (integrità)
  - Poter garantire che il contenuto e/o l'origine di un dato corrispondano a quanto si ritiene corretto
- Availability (disponibilità)
  - Poter garantire la possibilità effettiva di accedere a dati e servizi quando necessario



# Le minacce e gli attacchi

- **Minaccia (threat)**: una condizione che potenzialmente può compromettere una o più delle proprietà di sicurezza
  - Esiste indipendentemente dal fatto che venga concretizzata
  - **Attacco (attack)**: l'azione che porta al concretizzarsi di una minaccia
  - **Attaccante (attacker)**: l'entità che sferra l'attacco
- Le minacce sono indissolubilmente legate alle intenzioni dei potenziali attaccanti
  - Script kiddies
  - Criminali comuni
  - Insider disonesti e impiegati vendicativi
  - Reporter
  - Ricercatori
  - Attivisti
  - Criminali organizzati
  - Spie industriali
  - Governi ed eserciti

# Tipologie di attacchi e minacce





# Vulnerabilità ed exploit

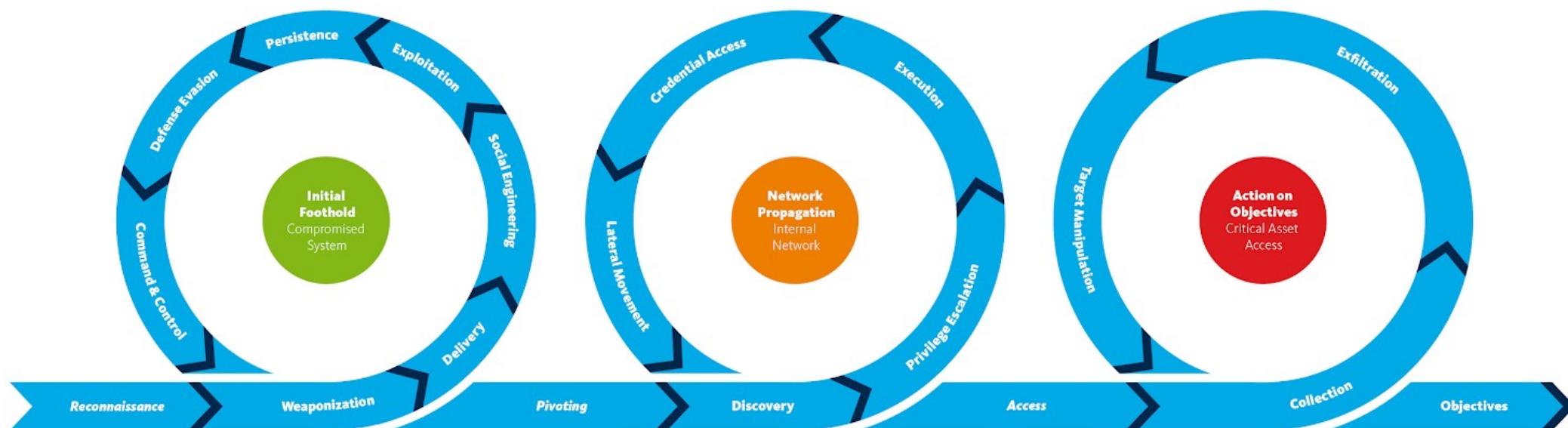
Termini che saranno definiti in seguito

- Se le **politiche** e i **meccanismi** di protezione di un sistema fossero perfetti, le minacce non potrebbero concretizzarsi
  - Neutralizzano i vettori di attacco
- Gli attacchi hanno successo se esistono errori
  - Nell'individuazione della superficie di attacco (porosità – un vettore esiste là dove non dovrebbe)
  - Nella definizione di una politica o nell'implementazione di un meccanismo (**vulnerabilità / vulnerability**)
    - Può essere strutturale nell'hardware o software
    - Può dipendere dalla configurazione
    - Può dipendere da un uso scorretto
- Exploit
  - Uno strumento per trarre vantaggio da una vulnerabilità concretizzando una minaccia
    - Tecnico (cracking)
    - Umano (social engineering)



# Come avviene un attacco

- I modi di entrare in un sistema sono vari e spesso usano come anello debole della catena l'essere umano
  - Spesso l'obiettivo è installare qualche tipo di malware (software malevolo)
    - che può consentire accesso al sistema – RAT Remote Access Trojan
    - che può rendere il sistema inutilizzabile – Cryptolocker, Ransomware
    - che esporta verso l'attaccante i dati della vittima - Spyware
    - che utilizza la vittima per effettuare altri attacchi – Botnet agent
- ma non solo...



# Obiettivi del corso

*Ethical hacking* – il processo in cui si adotta lo stesso approccio che impiegherebbero attaccanti malevoli, ma in un contesto controllato tecnicamente e legalmente, per scoprire le vulnerabilità prima che lo facciano loro

- Per valutare il livello di esposizione e di rischio
- Per comprendere meglio come progettare le contromisure

# Cosa faremo in questo corso

## ■ Finalità

- panoramica dei principali problemi pratici della sicurezza informatica
- Acquisizione delle basi delle tecniche offensive per la valutazione delle vulnerabilità e delle tecniche difensive per la loro mitigazione

## ■ 6 crediti / 60 ore divise circa 25 teoria + 35 pratica

## ■ Percorso

- 1) accesso illecito ai sistemi: come si ottiene, si rileva, si blocca, e si aggirano i blocchi
- 2) quando si è entrati: metodi di privilege escalation e strumenti per rilevare ed eliminare i percorsi possibili
- 3) attacchi al traffico in rete
- 4) elementi di crittografia e suo utilizzo per difendere i dati utente e le comunicazioni

# Programma – 1. Accesso ai sistemi

- Offensive security?
  - Vulnerability assessment e penetration testing
  - I primi passi della Kill Chain
- Enumerazione
- Vettori di attacco
  - Web: SQL injection, path traversal, e simili
  - Binari: buffer overflow e suo sfruttamento
- Protezione degli host con dispositivi di rete
  - configurazione di packet filtering firewall
- Modelli di intrusion detection
  - host based IDS: event management
  - analisi del traffico e network based IDS
- Back to offensive: ci sono modi per scavalcare firewall e IDS?
  - sicurezza fisica
  - supply chain / repo poisoning

# Programma – 2. Dall'interno

- Modelli di controllo dell'accesso e loro utilizzo per aumentare i privilegi
  - Permessi Linux e NTFS
  - Bit speciali, Capabilities, ACL
  - Privilegi di amministrazione
- Gestione dei processi
  - Strategie di occultamento e persistenza
- Rilevare le alterazioni al sistema
  - host based IDS: integrity checking

# Programma - 3. Attacchi al traffico

- Sniffing
  - Spoofing
  - Hijacking
- X
- LAN
  - WLAN
  - Internet
- Usare la rete per affossare i sistemi: DDoS

# Programma – 4. Crittografia e applicazioni

- Crittografia simmetrica
- Funzioni hash e robustezza delle password
  - Dictionary attacks, brute forcing
  - Linee guida per la scelta
- Crittografia asimmetrica e protezione del traffico
  - Autenticazione attiva
  - Accesso sicuro ai sistemi (SSH)
  - Public-key Infrastructure e TLS
  - IPSEC e altre VPN, TOR



# Orario

## ■ 15 settimane nette x 5 ore

3h mercoledì in LAB4

2h venerdì in aula 0.5

## ■ Sospensioni previste nell'arco delle 17 settimane di calendario:

– mercoledì 4 marzo

- Non si farà lezione, ma il laboratorio è a disposizione previo accordo coi tutor per consentire la soluzione di eventuali problemi di predisposizione

– Mercoledì 25 e venerdì 27 marzo (lauree)

– Venerdì 3 aprile (festività pasquali)

– Venerdì 1 maggio (festa del lavoro)

## ■ Restano ore in eccesso – molto probabile salto delle ultime lezioni in aula, ma passibili di cambiamento per necessità di recuperi o altro

**LEGGERE L'E-MAIL ISTITUZIONALE NON È UN OPTIONAL!**

# Materiale didattico

## ■ Libri di testo suggeriti

- Elencati sulla guida web del corso
- Non li seguiremo passo passo ma sono consigliati per consolidare e approfondire le conoscenze

## ■ La domanda che nessuno fa e tutti hanno in testa anche se non lo sanno: si può studiare solo sulle slide?

- No, per due motivi
  - Le slide servono solo per tenere il filo del discorso
  - Metà del corso è pratico.
- Però frequentando regolarmente e prendendo appunti, ripassando subito e facendo domande in aula o a ricevimento non appena sorgono dubbi, la cosa può funzionare.
- Oltre ai link via via inseriti su Virtuale, i libri suggeriti o altri simili sono consultabili anche attraverso la biblioteca d'Ateneo

<https://ebookcentral.proquest.com/lib/unibo/home.action>

accessibile anche da fuori rete Unibo via EZProxy

<https://sba.unibo.it/it/almare/servizi-e-strumenti-almare/ezproxy>

# Altro materiale e informazioni varie

## ■ La pagina delle guide web

- Descrizione del corso
- Regole
- Contatti

## ■ Virtuale

- Slide proiettate a lezione
- Tracce delle esercitazioni
- Link a risorse utili tra cui l'immagine di una macchina virtuale per Virtualbox che sarà il riferimento per svolgere tutti gli esercizi

# Supporto

- I tutor ufficiali del corso sono gli ingegneri
  - Leonardo Barone  
<https://www.unibo.it/sitoweb/leonardo.barone4>
  - Pierluca Peverè  
<https://www.unibo.it/sitoweb/pierluca.pevere2>
- Per ottimizzare il carico di lavoro, abbiamo costituito un “pool” coi tutor del corso di Amministrazione di Sistemi.
- Non contattate il docente o i singoli tutor, ma scrivete alla lista che li raggiunge tutti:  
[AmmSistemi-LabSicurezza@live.unibo.it](mailto:AmmSistemi-LabSicurezza@live.unibo.it)

# Dove trovarmi

- Naturalmente per questioni sensibili e per tutto ciò che riguarda gli esami, il docente è il riferimento
- E-mail/Teams: [marco.prandini@unibo.it](mailto:marco.prandini@unibo.it)
- Telefono: 05120 93867
- Ufficio: Primo piano del blocco nuovo,  
in fondo al corridoio oltre l'aula 5.7
- Non è stato fissato un orario di ricevimento, siete i benvenuti in ufficio anche senza preavviso, ma può succedere che non sia possibile ricevervi.  
Consiglio: scrivere un'email e concordare un appuntamento.  
L'email può essere usata anche per fare domande molto semplici, non sostituisce il ricevimento.

# Modalità d'esame

- Prova unica divisa in due parti
  - **Accertamento delle conoscenze teoriche (peso 40%)**
    - quiz da svolgere senza l'ausilio di alcun materiale
    - risultato disponibile immediatamente
    - voto sufficiente richiesto per procedere alla parte pratica
  - **Prova pratica (peso 60%)**
    - centrata sulle attività svolte in laboratorio (svolgimento di esercizi da completare autonomamente e/o sfide collettive di attacco e difesa)
    - consentito l'uso di materiale didattico, appunti, e componenti software realizzati in precedenza
- **Valutazione finale:**  
voto in trentesimi, media pesata della valutazione delle due parti

# Prova teorica

- Domande a risposta chiusa su tutto il programma, anche i comandi visti in lab
  - es.: vediamo nftables in laboratorio, potrebbe esserci una domanda che chiede in che catena inserire una regola per ottenere un certo effetto
- Non si può consultare materiale di alcun genere
- Penalizzazione per risposta sbagliata
- Parametri indicativi (di volta in volta potranno oscillare in un intorno di questi valori)
  - Durata: 45 minuti
  - Numero domande: 30-40
  - Risposte: vero-falso o scelta multipla
  - Risultato perfetto: 36 punti
  - Sufficienza: 18 punti

# Prova pratica

- 2 ore in totale
- Vengono proposti esercizi simili a quelli svolti in laboratorio, di tipo sia offensivo (conduzione di un attacco verso un sistema vulnerabile fornito) che difensivo (adozione di meccanismi di protezione delle reti o dei sistemi)
- Si possono consultare appunti, script autoprodotti, materiale del corso, documentazione (non piattaforme di scambio soluzioni)
- Temi:
  - strumenti di enumerazione, brute-forcing e intercettazione dati
  - sfruttamento di vulnerabilità via privilege escalation, su binari, su applicazioni web
  - sicurezza delle informazioni
    - crittografia (*es. consegna file firmati, decifrazione pacchetti da analizzare*)
    - protezione del traffico con ssh e vpn (*es. accesso a sistema da testare*)
  - configurazione firewall con nftables
  - analisi di tracciati di traffico misto lecito/malevolo
  - definizione di regole di monitoraggio e rilevazione intrusioni host- e network-based



# Workflow dell'esame

- Il giorno dell'esame, obbligatoriamente nella stessa seduta, si sostengono la prova teorica e, se ammessi, quella pratica
  - per superare l'esame devono risultare singolarmente sufficienti entrambe
- Prova teorica
  - correzione automatica su EOL
  - se superata consente l'accesso alla prova pratica
- Prova pratica
  - correzione manuale (non immediata)
- Calcolo della media pesata tra le prove
- Dopo qualche giorno: pubblicazione dei voti su AlmaEsami
- A richiesta, solo per modificare un voto già sufficiente: prova orale

# Tempistiche dell'esame

- Dopo i tempi necessari per la correzione (orientativamente 7-10 giorni), i risultati sono pubblicati su AlmaEsami.
- **Entro 4 giorni dalla pubblicazione dei risultati**, chi vuole rifiutare il voto o richiedere una prova orale integrativa deve contattare via e-mail il docente.
  - la prova orale può essere richiesta solo per modificare un voto già sufficiente, non per recuperare un'insufficienza
  - può abbassare o alzare il voto al più di 3 punti
  - può spaziare su qualsiasi argomento trattato nel corso, teorico o pratico
- **Scaduto il termine**, i voti saranno registrati senza che siano necessarie ulteriori richieste o conferme; chi ha necessità specifiche e documentate di verbalizzazione rapida, deve contattare il docente non appena sostenuto l'esame.
- Chi ha in carriera il corso integrato con Amministrazione di Sistemi, otterrà come voto la media dei due; è suggerito di contattare via e-mail il docente per chiedere la verbalizzazione dopo aver superato entrambi

**Chi ottiene un voto insufficiente alla prova pratica è tenuto a concordare un ricevimento per visionarla, e non potrà sostenere altri appelli prima di aver soddisfatto questo requisito**

# Appelli d'esame

- Già fissati e pubblicati coi relativi dettagli su AlmaEsami, le iscrizioni saranno aperte a breve
  - Giugno 2 appelli → laurea luglio
    - Causa indisponibilità dei laboratori (sì, persino prenotando a Natale 2025) il primo appello di giugno potrebbe non avere capienza per tutti; avranno priorità i laureandi
  - Luglio → laurea ottobre
  - Settembre → laurea ottobre
  - Fine ottobre (da fissare) → laurea dicembre
  - Gennaio 2027 → laurea febbraio 2027
  - Febbraio 2027 → laurea marzo 2027
- Notate che gli appelli sopra indicati sono tutti aperti a tutti gli studenti, ma collocati in modo ottimale per le relative scadenze di laurea
  - → non necessari (e quindi non concessi) appelli straordinari
- A causa di lavori programmati sul plesso, possono esserci modifiche
  - **LEGGERE L'E-MAIL ISTITUZIONALE NON È UN OPTIONAL!**